

Post-Exploitation Enumeration

Understanding a compromised Linux system before deciding what to do next

Session: Thursday — Parts 1 & 2

Target: Metasploitable 2

Attacker Host: Kali Linux

Focus: Identity, filesystem, users, services, network, and privilege escalation concepts

CONTENTS

01 Regaining Access

02 User & Privilege Enumeration

03 Basic System Enumeration

04 Operating System & Kernel Enumeration

05 Logged-in Users, Processes & Listening Services

06 Users, Groups & Scheduled Tasks

07 Installed Software & Network Enumeration

08 Exploring /etc, /var, /home, /root, /tmp

09 Environment Variables, Mounts & Disk Usage

10 Privilege Escalation Concepts

11 Key Takeaways & Defender Perspective

PART 1

Post-Exploitation Enumeration — Foundations

Goal: Post-exploitation enumeration is **not** about attacking the system further — it's about understanding the environment after gaining access. Before deciding what to investigate next, build a complete picture: identity, permissions, OS, software, users, services, and network connectivity.

01 Regaining Access

Metasploit module used to exploit the backdoored FTP service:

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS <target-ip>
run
```

Result:

```
Backdoor service has been spawned
UID: uid=0(root)
Command shell session opened
```

What Happened?

Metasploit exploited the backdoored **vsftpd 2.3.4** FTP server included in Metasploitable 2. The vulnerable daemon opened a hidden command shell listening on **TCP port 6200**. Metasploit simply connected to that shell.

IMPORTANT OBSERVATION

The victim machine created the shell — Kali only connected to it.

Why It Works

Metasploitable 2 intentionally contains vulnerable, unpatched software because the VM exists purely for security practice.

Level of Access

The shell immediately returned `uid=0(root)`, meaning:

- Highest possible Linux privilege
- No privilege escalation required
- Complete access to the system

DEFENDER PERSPECTIVE

A defender could observe: the FTP connection, an unexpected listener on port 6200, a new shell process, the network connection from attacker to backdoor port, and IDS/EDR alerts. Proper patching would eliminate this vulnerability entirely.

02 User & Privilege Enumeration

whoami

```
whoami
→ root
```

PURPOSE

Shows the current username — answers "Who am I?" Immediately tells an attacker whether they already have admin privileges.

Examples: `root` (highest privilege), `www-data` (web server account), `john` (regular user). This determines whether privilege escalation is necessary.

id

```
id
→ uid=0(root) gid=0(root)
```

Unlike `whoami`, `id` also shows UID, GID, and group memberships.

WHY ATTACKERS RUN IT

Answers "What exactly am I allowed to do?" A low-privilege account might belong to groups like `sudo`, `docker`, or `lxd` — memberships that can grant additional capabilities. UID 0 = root, which already has unrestricted permissions.

hostname

```
hostname
→ metasploitable
```

Identifies exactly which machine is currently under control — useful since attackers often compromise multiple systems (e.g. `WEB01`, `DB01`, `MAIL01`, `FILESERVER`). The machine's role guides later investigation.

03 Basic System Enumeration

pwd

```
pwd
→ /
```

Displays the current working directory — attackers first determine where their shell starts: `/` (filesystem root), `/home/user`, or `/var/www` (web shell).

ls — Top-Level Directories

Attackers don't search randomly — they visit directories intentionally based on the information they need:

/etc

Configuration files — most valuable directory during enumeration

/home

Normal users' home directories — docs, SSH keys, scripts

/root

Root's home directory — accessible only with root privileges

/var

Logs, web files, databases, mail

/tmp

Temporary files, frequently written by programs

/usr

Installed software and libraries

/proc

Virtual filesystem — process and kernel info

/dev

Device files representing hardware

/boot

Bootloader and kernel

/opt

Third-party applications

/mnt

Mounted filesystems

04 Operating System & Kernel Enumeration

```
cat /etc/*release
```

```
→ Ubuntu 8.04
```

Identifies the Linux distribution. Different distributions store files differently, use different package managers, and have different vulnerabilities. Ubuntu 8.04 is extremely old and unsupported.

```
uname -a
```

```
Linux  
2.6.24-16-server  
i686
```

Displays kernel information — the kernel controls memory, networking, hardware, filesystems, and processes.

UBUNTU VERSION	KERNEL VERSION
Operating system distribution	Actual operating system core

Kernel version is one of the first things professionals identify. Architecture `i686` means 32-bit x86.

05 Logged-in Users, Processes & Listening Services

who — Logged-in Users

```
msfadmin  tty1  
root      pts/0
```

TTY	PTS
Physical console	Pseudo-terminal (remote / graphical)

INTERESTING OBSERVATION

The Metasploit shell does NOT appear because it is not a standard login session.

`ps aux` — Running Processes

Displays every running process. Important columns: **USER, PID, CPU, Memory, COMMAND**.

Interesting services identified: Apache, SSH, MySQL, PostgreSQL, Tomcat, Samba, NFS, UnrealIRCd, DNS, Mail server, VNC, Ruby service, Cron.

The goal is not to read every process — professionals scan for interesting services.

`netstat -tulnp` — Listening Services

Maps **Port** → **Process**. Important discoveries:

PORT	PROCESS
22	sshd
80	apache2
3306	mysqld
5432	postgres
445	smbd
8180	Tomcat
6667	UnrealIRCd
6200	<code>sh</code>

HUGE LESSON

Monday: Nmap showed open ports (outside view). Thursday: Netstat confirmed exactly which programs owned those ports (inside view). Port 6200 belonging to `sh` confirmed the FTP backdoor shell was still active — outside and inside views matched perfectly.

06 Users, Groups & Scheduled Tasks

`/etc/passwd` — User Enumeration

Contains user account information. Modern Linux does **not** store passwords here — the second field `x` means password hashes live in `/etc/shadow`.

Each line contains: username, password placeholder, UID, GID, comment, home directory, default shell.

HUMAN USERS	SERVICE ACCOUNTS
msfadmin, user, service	mysql, postgres, www-data, daemon

<code>/BIN/BASH</code>	<code>/BIN/FALSE</code>
Interactive login allowed	Service account — cannot normally log in

`/etc/group` — Groups

Groups are permission containers — instead of assigning permissions per user, Linux commonly grants them to groups. Interesting memberships found: `adm`, `admin`, `lpadmin`, `sambashare`.

KEY LESSON

A username alone does not determine permissions — group memberships often provide additional capabilities.

Scheduled Tasks

```
crontab -l
→ no crontab for root
```

This means root has no *personal* scheduled tasks — it does not mean the machine has no cron jobs at all.

```
ls -l /etc/cron*
```

Enumerated: `/etc/crontab`, `cron.daily`, `cron.weekly`, `cron.monthly`, `cron.hourly` — observed maintenance tasks for Apache, APT, Tomcat, Samba, PostgreSQL, and log rotation.

07 Installed Software & Network Enumeration

`dpkg -l` — Installed Software

PS AUX	DPKG -L
Currently running software	Installed software (running or not)

Examples observed: Apache, APT, AppArmor, Java tools, Autoconf.

`ip addr` — Network Interfaces

Loopback interface `lo` (127.0.0.1) — the machine talking to itself. Main interface `eth0` shows MAC address, IPv4, and IPv6.

IMPORTANT OBSERVATION

Confirmed the machine's IP as `10.174.253.161` — matched the address attacked from Kali.

`ip route` — Routing Table

Local subnet: `10.174.253.0/24` • Default gateway: `10.174.253.248`

Devices inside the subnet communicate directly; traffic outside the subnet goes through the gateway. The routing table acts as the machine's navigation map.

Overall Workflow Learned

1. Who am I?
2. What permissions do I have?
3. Which machine is this?
4. Which OS and kernel is running?

5. What users exist?
6. What software is installed?
7. What services are running?
8. Which ports are open?
9. What scheduled tasks exist?
10. How is the machine connected to the network?

Only after building this complete understanding do professionals decide what to investigate next.

DEFENDER PERSPECTIVE

Every command run was read-only and focused on gathering information. Potential defender visibility includes interactive shell creation, FTP exploitation, command auditing (auditd), EDR process monitoring, IDS alerts, shell history, process inspection, and network telemetry.

Mitigations: patch vulnerable software, remove unnecessary services, apply least privilege, limit group memberships, monitor shell activity, audit scheduled tasks, keep software updated, use network segmentation, deploy IDS/EDR, and continuously monitor system logs.

Key Takeaways — Part 1

- Post-exploitation enumeration is about understanding the compromised system, not attacking it.
- Enumeration follows a logical order: identity → system → users → services → software → network.
- `whoami`, `id`, `uname`, `ps`, `netstat`, and `ip` each answer a specific question about the system.
- External enumeration (Nmap) and internal enumeration (`ps`, `netstat`) complement each other.
- `/etc/passwd` identifies users; `/etc/group` reveals permission groups.
- Scheduled tasks and installed packages reveal how the system is maintained.
- Network enumeration reveals interfaces, IP addresses, subnet, and gateway.
- Successful post-exploitation depends on collecting accurate information first, and acting on informed decisions rather than blindly.

PART 2

Filesystem Deep Dive & Privilege Escalation Concepts

Goal: Rather than exploiting further, collect information methodically and correlate it with earlier findings. This session covers filesystem exploration, environment info, mounted filesystems, disk usage, and the concepts behind privilege escalation.

08 Exploring /etc

```
ls /etc
```

Examples discovered: apache2, mysql, postgresql, samba, ssh, tomcat5.5, vsftpd.conf, passwd, shadow, group, cron.*, hosts, resolv.conf, exports, fstab.

IMPORTANT UNDERSTANDING

`/etc` stores configuration, not user data. Example: Apache's website files live in `/var/www`, but its configuration lives in `/etc/apache2`.

/ETC	/VAR	/HOME
How the system behaves	Data that changes at runtime	User files

Professionals don't inspect every file — they focus on configuration tied to services already discovered during enumeration.

`/etc/hosts`

```
cat /etc/hosts
```

A local hostname-to-IP mapping file. Linux checks this file **before** querying DNS.

```
127.0.0.1 localhost
```

WHY ATTACKERS LOOK HERE

On real networks this may reveal internal systems such as fileserver, database, backup, or domain controller — even if DNS is unavailable.

`/etc/resolv.conf`

```
search localdomain
nameserver 10.174.253.248
```

Tells Linux which DNS server to use. The `search localdomain` line lets `server1` automatically resolve as `server1.localdomain`. The configured DNS server often reveals network infrastructure details.

09 Exploring /var, /var/log & /var/www

```
ls /var
```

Important directories: backups, cache, lib, log, mail, tmp, www.

`/var` contains variable data — unlike `/etc`, its contents constantly change while the system runs (logs, websites, databases, caches, mail, runtime info).

`/var/log`

Discovered logs: apache2, auth.log, syslog, kern.log, mysql, postgresql, samba, tomcat5.5, vsftpd.log, proftpd.

Every major service records events here — authentication, service startup, errors, kernel events, web requests. Professionals correlate logs with Nmap findings, running processes, and listening ports rather than treating logs independently.

LOG ROTATION

Files like `auth.log` / `auth.log.0` or `syslog` / `syslog.0` show log rotation — old logs are renamed while new logs continue recording, and older logs are sometimes compressed (`.gz`).

`/var/www`

Contents included: dwwa, mutillidae, phpMyAdmin, tikiwiki, tikiwiki-old, phpinfo.php, index.php — Apache's web root.

This connects earlier findings: **Nmap** → **Apache running** → **filesystem** → **/var/www**. The web applications discovered during earlier web enumeration physically exist inside this directory.

10 /home, /root & /tmp

`/home`

Directories found: ftp, msfadmin, service, user. Windows equivalent: `C:\Users\`. Home directory paths seen earlier in `/etc/passwd` (e.g. `/home/msfadmin`) point directly here. Typical contents: documents, scripts, downloads, SSH configuration, personal config files.

`/root`

Contents: Desktop, `reset_logs.sh`, `vnc.log`. This is the root user's home directory — **not** `/home/root`. Administrators often store maintenance scripts, logs, backups, SSH keys, and automation here.

IMPORTANT OBSERVATION

The filename alone never proves a file's purpose — `reset_logs.sh` suggests a log-related script, but only its contents confirm exactly what it does.

`/tmp`

```
ls -la /tmp
→ drwxrwxrwt
```

STICKY BIT

The final `t` is the sticky bit. Everyone can create files in `/tmp`, but only the file's owner (or root) can delete it. Without the sticky bit, any user could delete every other user's temporary files.

Other files found: `.ICE-unix` , `.X11-unix` , `.X0-lock` , `4618.jsvc_up` — mostly runtime files for graphical services or Tomcat. Nothing here is expected to be permanent.

Filesystem Summary

PATH	PURPOSE
<code>/etc</code>	Configuration
<code>/var</code>	Changing data
<code>/home</code>	User files
<code>/root</code>	Root user's files
<code>/tmp</code>	Temporary runtime files

11 Environment Variables

`env`

- **TERM** — specifies terminal capabilities; used by programs like vim, nano, top to display correctly.
- **REMOTE_HOST** — showed the shell originated from `10.174.253.241` (the Kali machine).
- **PATH** — `/sbin, /bin, /usr/sbin, /usr/bin` . Linux searches these directories whenever a command like `ls` is run; without PATH, users would need to type `/bin/ls` every time.
- **PWD** — current working directory, equivalent to the output of `pwd` .
- **SHLVL** — indicates shell nesting level, since shells can launch other shells.

12 Mounted Filesystems & Disk Usage

`mount`

Displays every mounted filesystem. Important entries:

- **Root filesystem** — `/dev/mapper/metasploitable-root` , ext3, mounted on `/` .
- **/boot** — separate partition storing the Linux kernel and bootloader files.
- **proc** — virtual filesystem generated dynamically by the kernel (e.g. cpuinfo, meminfo); not stored on disk.
- **sys** — virtual filesystem representing hardware, drivers, and kernel devices.
- **tmpfs** — e.g. `/var/run` , `/dev` , `/dev/shm` ; stored in RAM, fast, cleared on reboot.
- **rpc_pipefs / nfsd** — internal filesystems used by the NFS server (connects to earlier lessons on rpc.statd, rpc.mountd, NFS architecture). These are **not** exported NFS shares.

`df -h` — Disk Usage

<code>MOUNT</code>	<code>DF -H</code>
"What filesystems exist?"	"How full are they?"

Main filesystem: Size 7.0G, Used 1.5G, Free 5.2G, Usage 22%.

NOTE ON TMPFS

Large tmpfs values represent maximum available RAM, not actual usage — current usage remained extremely small.

Professional Navigation Strategy

1. Identify services.
2. Inspect service configuration in `/etc`.
3. Inspect logs in `/var/log`.
4. Inspect service data (such as `/var/www`).
5. Correlate everything together.

Enumeration is about understanding the system rather than memorizing commands.

13 Privilege Escalation Concepts

Definition

Privilege escalation means moving from a lower-privileged account to a higher-privileged account after initial access has already been obtained.

```
Web user → Standard user → Root
```

Initial access and privilege escalation are two separate stages.

Why Attackers Attempt It

Initial access often provides limited permissions; higher privileges allow administrative control over the operating system. In this lab, no privilege escalation was required because the vsftpd 2.3.4 backdoor immediately returned `UID 0` (root).

Common Causes

- Software vulnerabilities
- Misconfigurations
- Weak permission management
- Outdated software
- Excessively privileged services

The operating system isn't "forgetting" security — privilege escalation generally results from weaknesses in software or configuration.

Professional Methodology

1. Obtain initial access.
2. Determine current privileges.
3. Enumerate the system thoroughly.
4. Analyze findings.
5. Validate issues only within authorized scope.
6. Report findings with remediation recommendations.

The objective is not simply to become root — it's to understand and document security weaknesses so they can be fixed.

Key Lessons — Part 2

- `/etc` contains configuration; `/var` contains changing operational data.
- `/home` stores regular users' files; `/root` stores the administrator's files.
- `/tmp` is a shared temporary workspace protected by the sticky bit.
- `/etc/hosts` is checked before DNS; `/etc/resolv.conf` specifies which DNS server Linux uses.
- `env` describes the current shell environment; `PATH` determines where Linux searches for executables.
- `mount` shows how storage is attached; `df -h` shows filesystem capacity and usage.
- Enumeration is the foundation of post-exploitation.
- Privilege escalation is about increasing permissions after gaining initial access — professionals only evaluate it after completing careful enumeration.